

Regulación, Compliance e Infraestructura de Inteligencia Artificial en Entornos Biomédicos: Ciclo de Vida, Gobernanza de Datos y Atribución de Responsabilidad

El despliegue de sistemas de Inteligencia Artificial (IA) en entornos clínicos transforma la práctica de la medicina, pero introduce desafíos técnicos, éticos y regulatorios de gran complejidad. El ciclo de vida de un sistema de IA clínico transcurre desde la adquisición de datos de salud y el entrenamiento del modelo, pasando por la arquitectura de infraestructura que lo aloja, hasta su certificación regulatoria y operación continua en entornos hospitalarios. En cada una de estas etapas se configuran responsabilidades legales y técnicas específicas. Cuando un sistema de IA falla en su diagnóstico o tratamiento, determinar la responsabilidad requiere un análisis riguroso de las normativas de privacidad, los marcos de aprobación de dispositivos médicos y la integridad de la infraestructura de soporte.

1. El dato (privacidad y gobernanza de la información médica)

La fase inicial del ciclo de vida de un sistema de IA clínico es la recopilación y curación de grandes volúmenes de datos de salud de pacientes reales. En esta etapa, el marco de cumplimiento normativo se intersecta directamente con el derecho a la privacidad y la confidencialidad médica, con diferencias fundamentales entre las jurisdicciones de Estados Unidos, Argentina y la Unión Europea.

1.1 El estándar de Estados Unidos: HIPAA, Safe Harbor y Expert Determination

La ley fundamental en los Estados Unidos para proteger la información de salud es la *Health Insurance Portability and Accountability Act* de 1996 (HIPAA). Esta normativa clasifica la información de salud como Información de Salud Protegida (ePHI en su variante electrónica). La aplicabilidad de la norma está delimitada por los conceptos de Entidades Cubiertas (*Covered Entities*, que incluyen hospitales, aseguradoras y proveedores de salud que interactúan con pacientes) y Socios Comerciales (*Business Associates*, terceros que procesan, mantienen o transmiten ePHI en representación de una Entidad Cubierta). La relación contractual obligatoria entre ambos actores se formaliza mediante un Acuerdo de Socio Comercial (*Business Associate Agreement*, BAA).

Para que un desarrollador de IA pueda entrenar modelos de aprendizaje profundo sin estar sujeto a las estrictas restricciones de la HIPAA, los datos de salud deben someterse a un proceso de desidentificación formal según lo estipulado en la sección 45 CFR § 164.514 del Código de Regulaciones Federales. Existen únicamente dos metodologías legales para lograrlo: el método de desidentificación *Safe Harbor* y el método *Expert Determination*.

El método *Safe Harbor* exige la eliminación de 18 identificadores específicos del paciente o de sus familiares, empleadores y miembros del hogar.

ID	Identificador Específico a Eliminar (45 CFR § 164.514)	Reglas y Variaciones de Aplicación Técnica
1	Nombres	Nombres completos, parciales o iniciales.
2	Subdivisiones geográficas	Cualquier unidad menor a un estado (calle, ciudad, condado, código ZIP). Se permite mantener los primeros tres dígitos del ZIP si la unidad formada por todos los ZIP con esos tres dígitos iniciales contiene a más de 20,000 personas; de lo contrario, se reemplaza por "000".
3	Elementos de fechas	Fechas relacionadas con un individuo (nacimiento, admisión, alta, muerte) y todas las edades sobre 89 años (deben agregarse en una sola categoría de "90 años o más").
4	Números de teléfono	Líneas fijas, celulares o satelitales del paciente o familiares.
5	Números de fax	Líneas de transmisión documental.
6	Direcciones de correo electrónico	Cuentas de correo electrónico de cualquier tipo.
7	Números de Seguro Social (SSN)	Identificación tributaria o gubernamental.
8	Números de historial clínico (MRN)	Identificadores internos de sistemas de historias clínicas electrónicas.
9	Beneficiarios de planes de salud	Números de pólizas de seguros médicos.
10	Números de cuenta	Cuentas bancarias, tarjetas de crédito o servicios.
11	Números de licencia/certificado	Licencias de conducir, matrículas profesionales.
12	Identificadores de vehículos	Patentes, números de chasis o de serie de motor.
13	Identificadores de dispositivos	Números de serie de marcapasos, prótesis u otros implantes.
14	URLs de red	Localizadores universales de recursos de internet.
15	Direcciones IP	Protocolos de internet de estaciones de trabajo o enrutadores.

ID	Identificador Específico a Eliminar (45 CFR § 164.514)	Reglas y Variaciones de Aplicación Técnica
16	Identificadores biométricos	Huellas dactilares, registros de voz, escaneos de iris.
17	Fotografías de rostro completo	Cualquier imagen comparable que permita identificar directamente al sujeto.
18	Códigos únicos	Cualquier otro número, característica o código de identificación única.

El método *Expert Determination* requiere que una persona con conocimientos científicos y estadísticos evalúe el conjunto de datos y determine que el riesgo de reidentificación es extremadamente pequeño en el entorno donde se divulgará. El experto debe documentar formalmente los métodos estadísticos y las mitigaciones aplicadas.

La falta de control de estos datos expone a las organizaciones a graves multas. El ciberataque de *ransomware* contra *Change Healthcare* en febrero de 2024 (perpetrado por el grupo ALPHV BlackCat) expuso la ePHI de aproximadamente 192.7 millones de personas. Este evento, catalogado como la mayor brecha de datos de salud en la historia de los Estados Unidos, implicó el pago de un rescate de 22 millones de dólares y costos totales que alcanzaron los 2.457 millones de dólares para finales de 2024.

En cuanto a las sanciones financieras directas aplicadas por la Oficina de Derechos Civiles (OCR), la multa histórica más grande bajo HIPAA sigue siendo el acuerdo de 16 millones de dólares con *Anthem Inc.* en 2018. Recientemente, en 2024, se aplicaron sanciones como la multa de 3 millones de dólares a *Solara Medical Supplies* y la penalización civil de 1.19 millones de dólares a *Gulf Coast Pain Management Consultants*, confirmando que en cada uno de estos casos el factor de fallo principal fue la ausencia de un análisis de riesgos de seguridad exhaustivo.

Para mitigar estos riesgos, la actualización de la *HIPAA Security Rule* de 2026 introdujo mandatos de ciberseguridad significativamente más rigurosos:

- **Autenticación Multifactor (MFA):** Obligatoria para todos los accesos remotos y portales administrativos que interactúen con ePHI.
- **Encriptación de Datos:** Pasa de ser una especificación "direccionable" a un estándar independiente y obligatorio para datos en reposo (AES-256) y en tránsito (TLS 1.2 como mínimo absoluto, promoviéndose TLS 1.3).
- **Segmentación de Red:** Implementación obligatoria de políticas y configuraciones para aislar la ePHI y prevenir el movimiento lateral de intrusos.
- **Inventario de Activos y Mapa de Red:** Exigencia de mantener un inventario documentado de todos los dispositivos que acceden a ePHI y un mapa físico/lógico de la red, actualizados y auditados anualmente.
- **Acuerdos de Nivel de Servicio (SLA):** Plazos estrictos para la desactivación de cuentas comprometidas (1 hora) y la activación de planes de contingencia (24 horas).

Ficha técnica de cumplimiento (HIPAA)

- **(a) Fuente primaria exacta:** *De-identification Guidance of the Protected Health Information under HIPAA* (45 CFR §164.514(b)). Enlace oficial: [HHS De-identification Guidance](#).
- **(b) Cifras, fechas y definiciones precisas:**
 - *PHI (Protected Health Information):* Información de salud identificable creada, recibida, mantenida o transmitida por una entidad cubierta o socio comercial.

- *Safe Harbor*: Eliminación estricta de 18 identificadores geográficos, de fechas, números telefónicos, direcciones de red IP, identificadores biométricos y fotos de rostro.
- *Expert Determination*: Aplicación de principios estadísticos y científicos por un experto para certificar que el riesgo de reidentificación es "muy pequeño".
- *Estadísticas de Brechas/Multas*: Ciberataque de *Change Healthcare* (febrero de 2024, afectó a 192.7 millones de personas [en registro revisado en julio de 2025], con costos de recuperación de USD 2.457 mil millones). Incidente de *Conduent Business Services* (62.2 millones de personas afectadas, reportado en octubre de 2025/2026). Multa de *Solara Medical Supplies* (USD 3 millones en 2024).
- **(c) Cita textual breve verídica**: En virtud de la desidentificación por vía de expertos, se estipula que un profesional capacitado: "Applying such principles and methods, determines that the risk is very small that the information could be used, alone or in combination with other reasonably available information, by an anticipated recipient to identify an individual".
- **(d) Relevancia para el ingeniero biomédico**: Al diseñar un canal de ingesta para algoritmos de IA, el ingeniero debe implementar rutinas de desidentificación automáticas para eliminar metadatos e imágenes faciales completas de archivos DICOM y bases de datos relacionales SQL, y garantizar la firma del BAA antes de transferir cualquier dato de salud a servicios de nube. La omisión de estos procesos constituye un fallo de diseño que traslada la responsabilidad legal de la fuga de datos directamente al equipo de desarrollo.

1.2 El marco de Argentina: Ley 25.326, AAIP y regulaciones vigentes

En la República Argentina, el marco normativo de datos está regido por la Ley de Protección de Datos Personales N° 25.326, sancionada en el año 2000. Bajo esta norma, la información de salud es clasificada como un "dato sensible" debido a que su revelación puede dar lugar a discriminación o vulnerar la intimidad profunda de la persona. El artículo 2 de la ley define explícitamente el "dato sensible" como datos que revelan el origen racial, opiniones políticas, convicciones religiosas, afiliación sindical e información referente a la salud o a la vida sexual. Los principios fundamentales de la Ley 25.326 imponen límites estrictos al ciclo de desarrollo de la IA clínica en territorio argentino:

- **Finalidad y no desviación**: Los datos recolectados no pueden ser utilizados para propósitos incompatibles con aquellos que motivaron su obtención original (Art. 4, inc. 3). El entrenamiento de una IA con historias clínicas de un hospital requiere el consentimiento expreso del titular, a menos que se aplique un proceso riguroso de disociación de datos (Art. 2, que define la disociación como el tratamiento donde la información no puede asociarse a persona determinada o determinable).
- **Seguridad y confidencialidad**: Se prohíbe registrar datos que no cumplan con condiciones de integridad y seguridad técnica, obligando tanto al responsable de la base de datos como a los intermediarios al secreto profesional absoluto, el cual subsiste aun después de finalizar la relación con el paciente (Art. 9 y Art. 10).
- **Cesión de datos**: La transferencia o cesión de datos médicos a terceros (por ejemplo, de un sanatorio a una startup desarrolladora de IA) requiere el consentimiento del titular, especificando el destino y la finalidad del tratamiento (Art. 11).
- **Transferencia internacional de datos**: El artículo 21 prohíbe la transferencia de datos personales de cualquier tipo a países u organismos internacionales que no proporcionen niveles de protección adecuados según el estándar de la autoridad de aplicación. Esta prohibición tiene excepciones limitadas, como la colaboración judicial internacional o contratos de transferencia basados en cláusulas estándar de protección.

La Agencia de Acceso a la Información Pública (AAIP) es la autoridad de aplicación nacional de la Ley 25.326. En el contexto del avance tecnológico, la AAIP ha emitido regulaciones específicas para la gobernanza algorítmica y la IA:

- **Resolución AAIP 161/2023:** Creó el "Programa de Transparencia y Protección de Datos Personales en el Uso de la Inteligencia Artificial". Este programa tiene como fin acompañar el desarrollo de tecnologías de IA en el ámbito público y privado, promoviendo la transparencia algorítmica y la auditoría de sesgos para evitar decisiones automatizadas discriminatorias en sectores sensibles como la salud.
- **Guía de Recomendaciones para una IA Responsable** (octubre de 2024): La AAIP publicó un marco práctico dirigido a entidades públicas y privadas. Esta guía establece pautas de "responsabilidad proactiva" (*accountability*) desde el diseño (*privacy by design*). Exige la implementación de Evaluaciones de Impacto en la Protección de Datos (DPIA) antes de entrenar o desplegar sistemas de IA, la calibración de la calidad del dato para mitigar sesgos algorítmicos, el derecho a la explicación de las decisiones automatizadas y el establecimiento de canales claros de comunicación para que los pacientes ejerzan sus derechos de acceso, rectificación y supresión.

Adicionalmente, se encuentra en debate parlamentario el proyecto de reforma integral de la Ley de Protección de Datos Personales (bajo el Mensaje PEN 87/2023). Este proyecto busca sustituir completamente la Ley 25.326 para armonizar la legislación nacional con el Reglamento General de Protección de Datos de la Unión Europea (GDPR), asegurando que la Argentina mantenga su estatus de "país adecuado" frente a la Unión Europea, ratificado por última vez en enero de 2024. El proyecto de reforma incluye innovaciones de alto impacto para los ingenieros biomédicos:

- **Multas proporcionales significativas:** Se introduce una escala de sanciones financieras basadas en la facturación del infractor, con un tope de hasta el 3% de la facturación local anual para las infracciones más graves (en comparación con el 4% de facturación global que establece el GDPR).
- **Sandboxes regulatorios:** Permite a la AAIP autorizar "entornos de prueba experimentales" temporales y controlados para iniciativas tecnológicas e IA innovadoras de menos de 5 años de antigüedad. Esto proporciona un carril legal seguro para validar algoritmos en fase piloto bajo condiciones reguladas antes de su despliegue comercial.
- **Gobernanza específica para IA:** Se proyecta que las disposiciones específicas sobre toma de decisiones automatizadas, elaboración de perfiles y sistemas de IA entren en vigencia de manera progresiva a los 30 meses de sancionada la reforma, otorgando previsibilidad al ecosistema de desarrollo de software médico.

Ficha técnica de cumplimiento (Argentina)

- **(a) Fuente primaria exacta:** Ley de Protección de Datos Personales N° 25.326 (Boletín Oficial, 2 de noviembre de 2000). Enlace oficial: [Infoleg Texto Ley 25.326](#). Guía de recomendaciones de la AAIP para una IA responsable (octubre de 2024). Enlace oficial de la Guía: Guía AAIP IA Responsable.
- **(b) Cifras, fechas y definiciones precisas:**
 - *Dato Sensible:* Datos que revelan información referente a la salud, origen racial, afiliación sindical, opiniones políticas o vida sexual (Art. 2).
 - *Tratamiento de Datos:* Operaciones sistemáticas de recolección, almacenamiento, modificación o cesión a terceros.
 - *Disociación de Datos:* Tratamiento mediante el cual la información no puede asociarse a persona determinada o determinable (Art. 2). * *Gobernanza Algorítmica (Res. AAIP 161/2023):* Establece el Programa Nacional de Transparencia y Protección de Datos Personales en el uso de la Inteligencia Artificial.

- *Proyectos de Ley de IA (2024-2026)*: Expediente 6156-D-2024 para crear el Registro Nacional de Sistemas de Inteligencia Artificial; proyecto de reforma de datos personales (Mensaje PEN 87/2023) que propone multas proporcionales del 3% de la facturación local y la creación de *sandboxes* regulatorios.
- **(c) Cita textual breve verídica**: El artículo 2 de la Ley 25.326 define: "Datos sensibles: Datos personales que revelan origen racial y étnico, opiniones políticas, convicciones religiosas, filosóficas o morales, afiliación sindical e información referente a la salud o a la vida sexual".
- **(d) Relevancia para el ingeniero biomédico**: El ingeniero que despliega un pipeline de entrenamiento o inferencia en Argentina debe asegurar que no se almacenen datos médicos crudos sin el consentimiento informado por escrito del paciente, a menos que el software aplique técnicas de disociación en el borde de ingesta. Además, debe someter sus sistemas a las guías éticas de la AAIP para evitar sanciones de cese de operaciones.

1.3 El contraste de la Unión Europea: GDPR y datos de salud

El Reglamento General de Protección de Datos (GDPR - Reglamento UE 2016/679) representa el estándar de privacidad más estricto a nivel global. A diferencia de la HIPAA estadounidense —que se enfoca en entidades del sector salud—, el GDPR tiene un alcance de aplicabilidad horizontal y aplica a cualquier organización que procese datos de ciudadanos europeos, independientemente de la ubicación geográfica de los servidores.

El artículo 9 del GDPR prohíbe de forma general el tratamiento de "categorías especiales de datos", las cuales incluyen expresamente los datos de salud, datos genéticos y datos biométricos dirigidos a identificar de manera exclusiva a una persona física. Para levantar esta prohibición en el contexto de la IA clínica, el desarrollador o la institución de salud debe encuadrar el tratamiento en alguna de las excepciones del Artículo 9(2):

- **Consentimiento explícito** (Art. 9(2)(a)): El paciente otorga una declaración libre, específica, informada e inequívoca para que sus datos sean procesados con fines de entrenamiento algorítmico. Este consentimiento debe ser revocable en cualquier momento, lo que presenta retos técnicos para desentrenar o retirar datos de modelos ya consolidados.
- **Medicina preventiva o diagnóstico médico** (Art. 9(2)(h)): El procesamiento es necesario para la prestación de asistencia sanitaria o tratamientos, realizado por o bajo la responsabilidad de un profesional sujeto al secreto profesional. Esta base legal cubre el uso de la IA en el flujo directo de atención al paciente, pero no necesariamente el uso secundario de los datos para investigación y desarrollo comercial de nuevos productos de IA.
- **Interés público en el ámbito de la salud pública** (Art. 9(2)(i)): Procesamiento necesario para garantizar altos estándares de calidad y seguridad de la asistencia sanitaria, medicamentos o dispositivos médicos, sobre la base del Derecho de la Unión o de los Estados miembros.

Las transferencias internacionales de datos bajo el GDPR (Artículos 44 al 49) exigen que el país receptor cuente con una decisión de adecuación emitida por la Comisión Europea o, en su defecto, que se implementen salvaguardas contractuales robustas como las Cláusulas Contractuales Tipo (SCCs) junto con Evaluaciones de Impacto de Transferencia (TIA). Las sanciones financieras por incumplimiento del GDPR pueden alcanzar hasta 20 millones de euros o el 4% de la facturación global anual del grupo empresarial del ejercicio anterior, aplicándose el monto que resulte superior.

Ficha técnica de cumplimiento (GDPR)

- **(a) Fuente primaria exacta:** Reglamento General de Protección de Datos (GDPR - Reglamento UE 2016/679). Enlace oficial: [EUR-Lex GDPR](#).
- **(b) Cifras, fechas y definiciones precisas:**
 - *Datos de Salud (Art. 9):* Categoría especial de datos personales relativos a la salud física o mental de una persona física, incluyendo la prestación de servicios de atención médica.
 - *Bases Legales de Excepción (Art. 9.2):* Consentimiento explícito, medicina preventiva/diagnóstico médico, interés público en salud pública.
 - *Transferencias Internacionales (Art. 44-49):* Exigen un nivel de protección adecuado certificado por decisión de adecuación (como la ratificada para Argentina en enero de 2024) o Cláusulas Contractuales Tipo (SCC).
 - *Multas:* Hasta 20 millones de EUR o el 4% de la facturación global anual del ejercicio anterior.
- **(c) Cita textual breve verídica:** El Artículo 9(4) del GDPR estipula la capacidad de los Estados miembros para introducir restricciones nacionales: "Member States may maintain or introduce further conditions, including limitations, with regard to the processing of genetic data, biometric data or data concerning health."
- **(d) Relevancia para el ingeniero biomédico:** Al diseñar herramientas de software clínico destinadas a la exportación o uso en pacientes de la UE, el ingeniero debe prever la revocabilidad del consentimiento (derecho al olvido, Art. 17) diseñando mecanismos que permitan borrar los datos clínicos del dataset o aislar la inferencia del usuario, garantizando que el almacenamiento de datos cumpla con los límites geográficos europeos.

2. El dispositivo (seguridad y eficacia del software médico - SaMD)

Cuando el algoritmo de IA pasa de la fase de entrenamiento al despliegue clínico para emitir predicciones, diagnósticos o recomendaciones que afectan directamente las decisiones médicas, deja de ser un simple software y se convierte legalmente en un dispositivo médico, específicamente clasificado como *Software as a Medical Device* (SaMD) o Software como Producto Médico.

2.1 El estándar de Estados Unidos: FDA y la regulación del PCCP

La Administración de Alimentos y Medicamentos de EE. UU. (FDA) adoptó el marco de categorización de riesgos desarrollado por el Foro Internacional de Reguladores de Dispositivos Médicos (IMDRF) en su documento N41. Este marco clasifica al SaMD en cuatro categorías de riesgo (I a IV), construidas mediante el cruce de dos dimensiones clave: la gravedad de la situación o condición de salud (*Crítica, Seria, No Seria*) y la importancia de la información provista por el SaMD para la toma de decisiones (*Tratar o Diagnosticar, Dirigir el Manejo Clínico, Informar el Manejo Clínico*).

Situación de Salud / Condición Médica	Tratar o Diagnosticar (Treat or Diagnose)	Dirigir el Manejo Clínico (Drive Clinical Management)	Informar el Manejo Clínico (Inform Clinical Management)
Crítica (Critical)	Categoría IV	Categoría III	Categoría II
Seria (Serious)	Categoría III	Categoría II	Categoría I
No Seria (Non-Serious)	Categoría II	Categoría I	Categoría I

Esta clasificación regulatoria determina los canales tradicionales de comercialización de la

FDA:

- **510(k) (Sustancial Equivalencia):** Utilizado cuando el fabricante demuestra que su SaMD de riesgo moderado es sustancialmente equivalente a un dispositivo preexistente ("predicado") legalmente comercializado. Es el camino más rápido (mediana de 151 días de revisión) y abarca aproximadamente el 96% de todas las autorizaciones de dispositivos de IA/ML hasta la fecha.
- **De Novo (Clasificación de Riesgo Bajo a Moderado sin Predicado):** Camino utilizado para tecnologías novedosas para las cuales no existe un predicado en el mercado, estableciendo controles especiales y sirviendo como precedente para futuras presentaciones 510(k).
- **PMA (Premarket Approval):** El proceso de revisión más riguroso, reservado para dispositivos de Categoría IV o Clase III que presentan un alto riesgo potencial. Requiere la realización de ensayos clínicos aleatorizados prospectivos para demostrar de forma concluyente la seguridad y eficacia del sistema.

Para abordar la naturaleza iterativa del software de aprendizaje automático —que cambia su desempeño al recibir nuevos datos de entrenamiento—, la FDA publicó el 3 de diciembre de 2024 la guía final titulada *Marketing Submission Recommendations for a Predetermined Change Control Plan for Artificial Intelligence-Enabled Device Software Functions*. Esta guía formaliza e implementa el concepto de Plan de Control de Cambios Predeterminado (PCCP), autorizado legalmente por la sección 515C de la Ley Federal de Alimentos, Medicamentos y Cosméticos (FD&C Act) sancionada en la reforma FDORA de 2022.

Un PCCP es una herramienta regulatoria proactiva incorporada dentro de la presentación premercado inicial (510(k), De Novo o PMA) que permite al fabricante realizar modificaciones específicas y planificadas en el algoritmo (como reentrenamiento con nuevos datos, optimizaciones de código o ampliación de variables de entrada) sin tener que realizar una nueva presentación de autorización de mercado ante la FDA cada vez que se actualiza el software. Un PCCP debe contener obligatoriamente tres secciones técnicas estructuradas:

- **Description of Modifications** (Descripción de Modificaciones): Define con precisión de ingeniería los límites de los cambios futuros (ej., nuevos conjuntos de datos de entrenamiento o variaciones en los parámetros de pesos de la red).
- **Modification Protocol** (Protocolo de Modificación): Detalla el método técnico de re-entrenamiento, control de calidad del dato, versionado, y las pruebas de validación clínica necesarias para verificar el correcto funcionamiento.
- **Impact Assessment** (Evaluación de Impacto): Evalúa los riesgos potenciales de cada modificación y documenta cómo el fabricante mantendrá la seguridad y eficacia del dispositivo durante su operación.

Ficha técnica de cumplimiento (PCCP FDA)

- **(a) Fuente primaria exacta:** *Marketing Submission Recommendations for a Predetermined Change Control Plan for Artificial Intelligence-Enabled Device Software Functions* (FDA, diciembre de 2024). Enlace oficial general: [FDA AI/ML Devices](#).
- **(b) Cifras, fechas y definiciones precisas:**
 - **PCCP (Plan de Control de Cambios Predeterminado):** Plan preaprobado en la sumisión comercial inicial que detalla modificaciones acotadas del algoritmo de IA, su protocolo de validación y la evaluación de impacto técnico sin requerir nuevos envíos regulatorios. Codificado en la sección 515C de la FD&C Act.
 - **Estadísticas:** FDA lleva autorizados más de 1,000 (en bases de datos de la industria se reportan más de 1,400) dispositivos médicos basados en IA/ML. De estos, aproximadamente el 96% se aprueba a través del canal de equivalencia sustancial 510(k). A finales de 2024, existían al menos 53 dispositivos autorizados

- bajo el esquema PCCP.
 - *Framework IMDRF (Documento N41)*: 4 categorías de riesgo (I-IV) basadas en el cruce de la seriedad de la condición de salud (Critical, Serious, Non-Serious) y el impacto de la información de salida (Treat/Diagnose, Drive Clinical Management, Inform Clinical Management).
- **(c) Cita textual breve verídica**: Sobre las ventajas de un PCCP, el marco normativo establece que este plan permite: "...reduce the need for repeated approvals and decrease waiting times for approval decisions, thereby fostering innovation and improving patient access to advanced technologies".
- **(d) Relevancia para el ingeniero biomédico**: El ingeniero que diseña algoritmos de aprendizaje automático adaptativos o iterativos debe estructurar la documentación de diseño siguiendo el formato PCCP (Description of Modifications, Modification Protocol, e Impact Assessment) para pre-aprobar el reentrenamiento continuo con datos reales y evitar que cada nueva versión del software deba esperar una aprobación regulatoria de 150 días.

2.2 Casos reales de dispositivos basados en IA aprobados por la FDA

La viabilidad técnica y regulatoria de los sistemas de IA médica se asienta sobre precedentes de validación clínica de alto rigor metodológico. El análisis de los primeros sistemas de diagnóstico autónomo aprobados por la FDA proporciona un mapa de diseño y una línea de base para evaluar nuevos desarrollos.

Ficha técnica de cumplimiento (Casos Clínicos)

- **(a) Fuente primaria exacta**: FDA De Novo Decision Summary para IDx-DR (DEN180007). Enlace del estudio pivotal: [PMC6550188](#) e ID ClinicalTrials: [NCT02963441](#). Para Viz LVO (DEN170073), enlace de publicación: [Viz.ai stroke study](#).
- **(b) Cifras, fechas y definiciones precisas**:
 - *IDx-DR*: Autorizado en abril de 2018 vía De Novo como el primer dispositivo de diagnóstico autónomo basado en IA. El estudio clínico pivotal prospectivo analizó a 900 pacientes con diabetes en 10 centros de atención primaria, de los cuales 819 completaron la evaluación integral. Demostró una sensibilidad del 87.2\% (95% CI: 81.8\% - 91.2\%) y una especificidad del 90.7\% (95% CI: 88.3\% - 92.7\%) para detectar retinopatía diabética más que leve (mtmDR) con una tasa de evaluabilidad del 96.1\%.
 - *Viz LVO (ContaCT)*: Autorizado en febrero de 2018 vía De Novo. Analiza imágenes de angiotomografía cerebral para oclusión de grandes vasos (LVO). En un estudio retrospectivo secuencial de 2,544 pacientes de 139 hospitales, reportó una sensibilidad del 96.32\% (95% CI: 92.6\% - 98.8\%) y una especificidad del 93.83\% (95% CI: 92.8\% - 94.7\%).
 - *CINA LVO*: Dispositivo aprobado para priorizar tomografías de sospecha de accidente cerebrovascular. En el estudio retrospectivo multi-centro de 378 escaneos de McLouth et al. (2021), el algoritmo CINA demostró una exactitud del 98\%, una sensibilidad del 94.3\% y una especificidad del 97.4\% en la detección de subtipos de LVO.
- **(c) Cita textual breve verídica**: El protocolo del estudio de IDx-DR define el éxito estadístico en base a los umbrales exigidos por la FDA: "The IDX goal is to deliver a level of performance that aligns with the FDA's target that the IDX-DR Device rule out lower bounds of at least 75% sensitivity and at least 77.5% specificity for the mtmDR

configuration".

- **(d) Relevancia para el ingeniero biomédico:** Estos casos de estudio demuestran al ingeniero que la validación clínica no puede basarse únicamente en pruebas de software retrospectivas con datos de laboratorio (*standalone software testing*); los algoritmos deben superar la variabilidad clínica y la baja calidad de imagen de operadores no expertos en condiciones del mundo real para garantizar su seguridad y eficacia.

2.3 Regulación de ANMAT en Argentina y contraste con la UE (MDR e EU AI Act)

La comercialización y el uso de software médico e IA en Argentina e internacionalmente requieren la alineación del expediente técnico con directrices específicas de los organismos sanitarios.

En la República Argentina, la Administración Nacional de Medicamentos, Alimentos y Tecnología Médica (ANMAT) regula el software médico principalmente a través de la Disposición ANMAT N° 9688/2019, sancionada el 29 de noviembre de 2019 y publicada en el Boletín Oficial el 3 de diciembre de 2019. El artículo 26 establece formalmente la obligatoriedad de inscribir el software autónomo o embebido en el Registro de Productores y Productos de Tecnología Médica (RPPTM).

La norma determina directrices de exclusión e inclusión para regularizar el ecosistema de software biomédico en la Argentina:

- **Inclusión como software autónomo (SaMD):** Los programas informáticos autónomos que se encuadran en la definición de producto médico se considerarán "productos médicos activos".
- **Exclusiones de software general:** Se excluyen expresamente los programas informáticos de uso administrativo general en el marco de la asistencia sanitaria o aquellos destinados al bienestar general o estilos de vida saludables que no realizan diagnóstico ni terapia directa.
- **Requisitos técnicos obligatorios de inscripción:** El software debe satisfacer los Requisitos Esenciales de Seguridad y Eficacia (RESE) establecidos originalmente por la Disposición ANMAT N° 4306/1999. Para ello, el fabricante o importador debe presentar documentación técnica que acredite la evaluación de diseño del software, la gestión sistemática de riesgos (conforme a la norma ISO 14971) y reportes completos de verificación y validación (V&V) aplicados en cada una de las fases del ciclo de vida definido.
- **Clasificación de riesgo de productos médicos:** Se estructuran cuatro clases de riesgo (Clase I, II, III, IV), donde las solicitudes de Clase III y IV están sujetas a un control riguroso premercado y las modificaciones de registro se limitan a datos no característicos (Art. 1, Art. 14).

En contraste con la flexibilidad regulatoria relativa de ANMAT, la Unión Europea exige el cumplimiento del Reglamento de Dispositivos Médicos (MDR - Reglamento UE 2017/745), cuya Regla 11 clasifica al software diagnóstico y de monitoreo crítico en las clases de riesgo IIa, IIb o III. Adicionalmente, se superpone la Ley de Inteligencia Artificial (EU AI Act - Reglamento UE 2024/1689), la cual, bajo el Artículo 6(1), cataloga automáticamente a estos dispositivos médicos que incorporan IA como sistemas de "alto riesgo" (*high-risk AI systems*). Esto obliga a los desarrolladores a cumplir con requisitos específicos de gobernanza de datos, documentación técnica de algoritmos, mitigación de sesgos algorítmicos, trazabilidad mediante registros automatizados y mecanismos robustos de supervisión humana y ciberseguridad.

Ficha técnica de cumplimiento (ANMAT y UE)

- **(a) Fuente primaria exacta:** Disposición ANMAT N° 9688/2019. Enlace oficial: [Disposición ANMAT 9688/19](#). Reglamento de la UE sobre IA (Reglamento UE 2024/1689). Enlace oficial: [EUR-Lex AI Act Article 6](#).
- **(b) Cifras, fechas y definiciones precisas:**
 - *Art. 26 ANMAT:* El software autónomo médico se considerará producto médico activo. Se adopta la colaboración internacional con el IMDRF (marzo de 2026).
 - *Art. 6(1) EU AI Act:* Los sistemas de IA embebidos o independientes de marcado CE que requieran evaluación de conformidad de terceros bajo el MDR (Clase IIa, IIb y III) son clasificados como IA de "alto riesgo" (*high-risk*), debiendo cumplir de forma obligatoria con la norma a partir del 2 de agosto de 2027.
- **(c) Cita textual breve verídica:** El artículo 26 de la Disposición ANMAT 9688/2019 establece: "Los programas informáticos que constituyan el software en sí mismo (autónomos) se considerarán productos médicos activos, quedando excluidos los programas informáticos para usos generales administrativos que son utilizados en el marco de la asistencia sanitaria."
- **(d) Relevancia para el ingeniero biomédico:** El ingeniero debe coordinar el diseño de software para que cumpla tanto con los requisitos de la ANMAT como con las normas del marcado CE europeo si aspira a exportar la tecnología. Ello exige unificar los expedientes de validación de algoritmos, gobernanza de datos y mitigación de sesgos bajo los rigurosos estándares técnicos del AI Act y del MDR.

3. Hardware e infraestructura

La construcción de un algoritmo clínico eficaz y su registro como dispositivo médico carecen de valor si la infraestructura de hardware sobre la cual opera el sistema no cumple con los estándares internacionales de seguridad física, eléctrica y cibernética.

3.1 Estándares internacionales fundamentales: IEC 62304 e IEC 60601-1

La seguridad de los sistemas electromédicos y su software asociado está regida por dos estándares internacionales reconocidos a nivel global por la FDA, ANMAT y la Unión Europea:

- **IEC 62304 (Ciclo de Vida del Software de Dispositivos Médicos):** Este estándar define un marco de procesos comunes para el desarrollo y mantenimiento del software médico, aplicándose tanto a sistemas autónomos (SaMD) como a software embebido en hardware clínico. La norma clasifica el software en tres clases de seguridad según la gravedad del daño potencial que un fallo algorítmico o de ejecución pueda infligir al paciente o usuario:
 - *Clase A:* No es posible que ocurra ninguna lesión o daño a la salud física del paciente.
 - *Clase B:* Posibilidad de lesión de carácter no grave.
 - *Clase C:* Posibilidad de muerte o lesión grave del paciente.
- **IEC 60601-1 (Seguridad Eléctrica y Funcionamiento Esencial de Equipos Electromédicos):** Estándar aplicable a los equipos de hardware médico con conexión eléctrica destinados al cuidado de pacientes. El estándar adopta un enfoque basado en el análisis de riesgos según la norma ISO 14971. Su **Sección 14** introduce requisitos específicos para los Sistemas Electromédicos Programables (PEMS), es decir, sistemas que incorporan hardware eléctrico y chips con microprocesadores que ejecutan software de control. La Sección 14 de la IEC 60601-1 exige que el fabricante establezca procesos rigurosos de especificación, diseño, verificación y validación para el subsistema

programable, requiriendo la convergencia con la norma IEC 62304 cuando el software controla aspectos clave de la seguridad básica o el funcionamiento esencial del equipo de hardware.

Ficha técnica de cumplimiento (IEC 62304 / IEC 60601-1)

- **(a) Fuente primaria exacta:** Norma Internacional IEC 62304:2006 (Enmienda 1: 2015) e IEC 60601-1:2005 (Sección 14 para PEMS). Enlaces de guías técnicas: [Formly Guide to IEC 62304](#) y [Nectar PD IEC 60601-1](#).
- **(b) Cifras, fechas y definiciones precisas:**
 - *IEC 62304*: Define los procesos del ciclo de vida del software de dispositivos médicos, clasificándolo en:
 - *Clase A*: No hay posibilidad de daño o lesión a la salud.
 - *Clase B*: Posibilidad de lesión de carácter no grave.
 - *Clase C*: Posibilidad de muerte o lesión grave del paciente.
 - *IEC 60601-1 (Sección 14)*: Regula el ciclo de desarrollo de los Sistemas Electromédicos Programables (PEMS), integrando la seguridad eléctrica del hardware clínico con el análisis de riesgos de software bajo ISO 14971.
- **(c) Cita textual breve verídica:** Sobre la flexibilidad documental de la IEC 62304, el estándar establece: "This standard does not prescribe the name, format, or explicit content of the documentation to be produced. This standard requires documentation of TASKS, but the decision of how to package this documentation is left to the user of the standard.".
- **(d) Relevancia para el ingeniero biomédico:** El ingeniero de software debe estructurar la arquitectura del sistema de IA clínico para poder realizar una modularización efectiva. Al independizar módulos críticos (Clase C) de módulos informativos o de interfaz de usuario (Clase A o B), se puede reducir significativamente el costo y el volumen de validación de código y pruebas de cobertura unitaria que exige la certificación del dispositivo.

3.2 Arquitecturas de despliegue en salud: implicancias de compliance y el BAA en la nube

El ingeniero biomédico debe seleccionar y diseñar el modelo de arquitectura de hardware adecuado para alojar el sistema de IA clínico, enfrentando decisiones que impactan la latencia clínica, la soberanía de los datos y el cumplimiento regulatorio de la privacidad.

El despliegue en infraestructuras de nube de hiperescala (*Hyperscalers*) como Amazon Web Services (AWS), Microsoft Azure y Google Cloud Platform (GCP) opera bajo el **Modelo de Responsabilidad Compartida**: el proveedor de la nube es responsable de asegurar la infraestructura física y el hipervisor de virtualización ("seguridad de la nube"), mientras que la institución de salud y el desarrollador del software de IA asumen la responsabilidad total por la configuración de los servicios lógicos, el cifrado de datos médicos, el control de identidades (IAM) y la habilitación de la autenticación multifactor ("seguridad en la nube"). Las tres plataformas firman Acuerdos de Socios Comerciales (BAA) condicionados al cumplimiento de estas configuraciones del cliente.

Ficha técnica de cumplimiento (Modelos de Despliegue)

- **(a) Fuente primaria exacta:** *AWS Business Associate Addendum (BAA)* de Amazon Web Services (Online Agreement) y *GCP HIPAA Implementation Guide*. Enlace de referencia general: [AWS HIPAA Compliance](#).

- **(b) Cifras, fechas y definiciones precisas:**
 - *Modelos de Despliegue:*
 - *Cloud:* Procesamiento remoto centralizado. Ofrece escalabilidad masiva, pero enfrenta problemas de latencia de red e implica transferencia internacional de datos personales (GDPR Art. 44 y Ley 25.326 Art. 21).
 - *On-Premises:* Servidores físicos locales del hospital. Control directo y nula latencia de red, pero altos costos de mantenimiento y parches de seguridad.
 - *Edge/Embedded:* Procesamiento en hardware local integrado (ej. GPU integrada en un ecógrafo). Minimiza latencia y dependencia de red, ideal para uso en quirófano.
 - *BAA Contractual:* AWS, Google Cloud y Azure firman BAA bajo la condición expresa de que el cliente configure la encriptación de los datos (reposo y tránsito), active los registros de auditoría y utilice únicamente los servicios elegibles del catálogo "HIPAA-Eligible Services Reference".
- **(c) Cita textual breve verídica:** Los términos contractuales de la BAA de AWS estipulan de forma explícita: "...compliance obligations are conditional on the in-scope services covered by the Addendum being configured correctly by the customer, that audit logging is enabled, and that all PHI placed into the AWS Cloud is encrypted".
- **(d) Relevancia para el ingeniero biomédico:** Al diseñar un sistema que consume servicios de IA en la nube, el ingeniero biomédico debe verificar que la API de la nube que invoca (como motores de visión computacional o analítica de lenguaje) esté explícitamente listada como HIPAA-eligible, configurar claves criptográficas gestionadas por el cliente (KMS) y asegurar que ningún dato médico crudo salga de los límites territoriales de residencia de datos exigidos por la ley local.

3.3 El patrón histórico de fugas de datos y la encriptación obligatoria

La evolución de las directrices de ciberseguridad en salud responde directamente a la persistencia de fallos sistémicos observados en auditorías forenses de las últimas dos décadas. Históricamente, el análisis de las brechas de seguridad registradas ante la OCR demostraba que el robo de dispositivos físicos (laptops de personal médico, discos duros externos de respaldo sin cifrar, cintas magnéticas de almacenamiento o estaciones de trabajo en laboratorios clínicos) representaba una de las causas más frecuentes de vulneración masiva de datos médicos. Bajo el marco de la actualización de la *HIPAA Security Rule* en 2026, la encriptación de datos se eleva formalmente a un estándar obligatorio independiente, eliminando la antigua flexibilidad que permitía a los ingenieros y hospitales optar por medidas alternativas si consideraban que el cifrado no era técnicamente viable. Esto obliga a los ingenieros biomédicos a estructurar controles técnicos de protección "en reposo" (AES de 256 bits) y "en tránsito" (TLS 1.2 o superior, promoviéndose TLS 1.3).

Ficha técnica de cumplimiento (Encriptación Mandatoria)

- **(a) Fuente primaria exacta:** HIPAA Security Rule (45 CFR §164.312) con la actualización de 2026 sobre encriptación mandatoria de datos de salud en reposo y tránsito. Enlace oficial: [HHS HIPAA Security Rule](#).
- **(b) Cifras, fechas y definiciones precisas:**
 - *Estadística:* Históricamente, más del 80% de las brechas de seguridad registradas en el portal de la OCR eran provocadas por intrusiones cibernéticas o robo de dispositivos físicos desprovistos de encriptación básica. En 2025, el promedio del costo de una brecha en salud alcanzó un récord de USD 7.42 millones de dólares

- según el IBM Cost of a Data Breach Report.
- **Encriptación Mandatoria:** Con la actualización del 2026 de la HIPAA Security Rule (con plazo de gracia de cumplimiento de 240 días tras su publicación final), el cifrado de ePHI pasa de ser una especificación "direccionable" a un estándar independiente obligatorio. Exige AES de 256 bits para datos en reposo y TLS 1.2 o superior (con preferencia por TLS 1.3) para datos en tránsito.
- **(c) Cita textual breve verídica:** El análisis de las estadísticas de breaches de salud de la OCR demuestra la reducción del robo de dispositivos desprovistos de encriptación básica: "Loss and theft incidents are becoming far less common due to the shift to cloud storage of PHI, and easier-to-implement and more cost-effective encryption options."
- **(d) Relevancia para el ingeniero biomédico:** Al diseñar dispositivos médicos físicos portátiles o servidores de borde para el hospital, el ingeniero debe programar rutinas de cifrado de almacenamiento de datos automático y forzar la deshabilitación del envío de tramas de comunicación clínica (como tramas HL7 de datos de pacientes o archivos DICOM de imagenología) en canales de texto claro o protocolos desprovistos de seguridad TLS robusta.

4. Responsabilidad y caso de cierre

Determinar la atribución de responsabilidad legal ante el fallo de un algoritmo de IA clínica requiere comprender la interacción de múltiples actores durante el ciclo de vida del producto. El análisis de estas responsabilidades se complementa con el estudio detallado de casos históricos reales de fallos en la gobernanza de datos de salud.

4.1 Distribución de responsabilidades legales ante fallos algorítmicos

Cuando un sistema de IA clínico falla —por ejemplo, si emite un falso negativo que retrasa un tratamiento de cáncer crítico, o si un falso positivo provoca una intervención quirúrgica innecesaria con secuelas graves—, la responsabilidad jurídica se analiza bajo un esquema de distribución de roles y responsabilidades que involucra a tres actores principales:

- **El Fabricante / Desarrollador de Software:** Asume la responsabilidad del producto por fallas inherentes al diseño, programación o validación del algoritmo. Si el software experimenta *Model Drift* (degradación progresiva del desempeño del modelo debido a cambios en la distribución de los datos clínicos de entrada a lo largo del tiempo o obsolescencia del hardware de adquisición de datos sin calibración) y el fabricante no implementó un protocolo robusto de vigilancia poscomercialización (*Post-Market Surveillance*, PMS) para detectar este desvío, la responsabilidad civil por daños recae de forma directa sobre la empresa proveedora de la tecnología.
- **La Institución de Salud:** Asume la responsabilidad institucional y civil por negligencia operativa si el sistema de IA se despliega sobre una infraestructura de red vulnerable, si se ignoran las alarmas técnicas de seguridad informática o si no se brinda el entrenamiento clínico adecuado al personal de salud sobre los límites de uso del software médico. Asimismo, la institución es responsable por fallos de integración de los datos.
- **El Ingeniero de Despliegue / Administrador de la Infraestructura:** Asume responsabilidad profesional y administrativa ante negligencias en la configuración criptográfica, la deshabilitación de registros de auditoría obligatorios o el retraso en la aplicación de parches de seguridad para corregir vulnerabilidades críticas dentro de los plazos obligatorios de la ley (ej., 15 días calendario para parches críticos según las reglas HIPAA).

Ficha técnica de cumplimiento (Distribución de Responsabilidad)

- **(a) Fuente primaria exacta:** FDA Draft Guidance on Clinical Decision Support (CDS) Software (2022), y lineamientos internacionales de post-market surveillance bajo el Reglamento MDR de la UE.
- **(b) Cifras, fechas y definiciones precisas:**
 - *Fabricante:* Responsable civil por diseño algorítmico defectuoso o sesgos no mitigados. Debe operar planes de vigilancia post-mercado (PMS) y calibración para controlar el desgaste del modelo (*Model Drift*), es decir, la degradación sistemática de la exactitud de inferencia algorítmica ante cambios en los datos de entrada en el tiempo.
 - *Institución de Salud:* Responsable de la integración operativa, la asignación de roles de acceso clínico adecuados, la seguridad perimetral de red y la capacitación médica del personal clínico.
 - *Ingeniero de Despliegue:* Responsable directo de mantener la integridad del pipeline de datos, la configuración criptográfica, la implementación de parches de seguridad críticos dentro de plazos rigurosos (ej. parches críticos dentro de 15 días y alta severidad dentro de 30 días según la regla HIPAA de 2026) y la documentación de auditoría exigida.
- **(c) Cita textual breve verídica:** Respecto al riesgo de fallos por una falta de control predictor y mantenimiento posterior, el reporte de la OCR ante el Congreso advierte: "...many data breaches could have been prevented through proactive compliance, rather than addressing security issues after exploitation."
- **(d) Relevancia para el ingeniero biomédico:** El ingeniero debe coordinar de forma constante el monitoreo clínico del software en el entorno operativo hospitalario, evaluando periódicamente si el modelo de IA experimenta degradación de métricas de sensibilidad o especificidad, y documentar rigurosamente los registros de auditoría técnica exigidos ante auditorías regulatorias para deslindar responsabilidades ante fallos algorítmicos.

4.2 Caso de estudio: Royal Free NHS Foundation Trust y Google DeepMind (Streams, 2017)

La investigación liderada por la Oficina del Comisionado de Información del Reino Unido (ICO) en 2017 respecto al acuerdo firmado entre el *Royal Free London NHS Foundation Trust* y la empresa de IA *Google DeepMind Technologies* constituye el caso de estudio clínico de referencia global sobre la gobernanza y privacidad de datos médicos en el entrenamiento y despliegue de sistemas de software biomédicos.

Cronología del caso

- **30 de septiembre de 2015:** Se firma el Acuerdo de Compartición de Datos (ISA) entre el *Royal Free NHS Foundation Trust* y *Google DeepMind* para cooperar en el desarrollo e integración de una aplicación móvil llamada *Streams*, destinada a alertar a los clínicos sobre pacientes con riesgo de sufrir Lesión Renal Aguda (AKI). El Trust transfiere de forma masiva registros médicos de aproximadamente 1.6 millones de pacientes históricos. El Trust operó bajo el supuesto de que esta transferencia masiva se amparaba en el "consentimiento implícito del paciente para el cuidado directo de la salud".
- **18 de noviembre de 2015:** Se inicia el flujo constante de datos en tiempo real (*data streaming*) desde los sistemas del Royal Free hacia los servidores de prueba

administrados por Google DeepMind, con propósitos exclusivos de testeo de seguridad clínica del software.

- **Abril de 2016:** El acuerdo (ISA) firmado en 2015 se hace público tras una solicitud de acceso a la información basada en la ley *Freedom of Information* (FOI), lo cual desata un debate público sobre el acceso de multinacionales tecnológicas a información médica sensible sin consentimiento explícito de los titulares de los datos.
- **Mayo de 2016:** Ante la preocupación pública sobre la escala y la privacidad de los datos compartidos, la ICO del Reino Unido abre de oficio una investigación formal de protección de datos sobre el Trust y DeepMind.
- **Febrero de 2017:** La aplicación móvil *Streams* (registrada ante la MHRA como un dispositivo médico de Clase I no medidor con marcado CE) finaliza su fase piloto de pruebas clínicas e inicia su despliegue activo en vivo para ser utilizada por los médicos del hospital en el flujo de cuidado de pacientes dentro del hospital.
- **3 de julio de 2017:** La ICO publica oficialmente su resolución final de la investigación y requiere la firma de un compromiso formal de cumplimiento normativo al Trust.

Normas e infracciones técnicas identificadas por la ICO La investigación forense liderada por la Comisionada de Información, Elizabeth Denham, determinó que el *Royal Free NHS Foundation Trust* incumplió de forma directa la Ley de Protección de Datos de 1998 (DPA 1998, marco vigente en ese período) al transferir los datos de 1.6 millones de pacientes. Las infracciones técnicas identificadas incluyeron:

- **Inadecuada Base Legal (Principio 1 de la DPA 1998):** El Trust alegó que la transferencia masiva de registros se amparaba en el "consentimiento implícito para cuidado directo", pero la ICO dictaminó que la fase inicial del proyecto consistía en pruebas de seguridad clínica, desarrollo algorítmico e integración de software (*clinical safety testing*), procesos que constituyen un propósito secundario que no puede justificarse bajo la base del cuidado médico directo de un paciente activo. Los pacientes no tenían expectativas de que su información médica histórica se utilizara para esta finalidad de testeo tecnológico privado sin su conocimiento previo.
- **Falta de Proporcionalidad y Exceso de Datos (Principio 3 de la DPA 1998):** Se determinó que no era técnicamente necesario ni proporcionado que DeepMind accediera y procesara los expedientes clínicos completos de 1.6 millones de pacientes históricos para entrenar y realizar pruebas de seguridad en vivo del algoritmo de detección de lesión renal, dado que la inmensa mayoría de esos registros pertenecían a pacientes sin patologías renales.
- **Falta de Transparencia e Imposibilidad de Exclusión (Principio 6 de la DPA 1998):** El Trust no informó adecuadamente a los pacientes sobre el procesamiento masivo de datos que realizaba DeepMind en su infraestructura, impidiéndoles ejercer su derecho de oposición o exclusión voluntaria (*opt-out*) del sistema.
- **Ausencia de Evaluación de Impacto (DPIA):** El procesamiento de un volumen masivo de datos de salud sensibles se inició sin realizar una evaluación de impacto en la privacidad previa, omitiendo la identificación de riesgos y las medidas de mitigación técnica antes de iniciar las transferencias de datos.

Resolución y por qué no se aplicó una multa

A pesar de las infracciones sustantivas documentadas sobre el manejo de 1.6 millones de registros de salud de pacientes reales sin consentimiento explícito, la ICO no aplicó una sanción financiera o multa económica contra el Trust. Esta decisión se debió principalmente a que, bajo el marco legal de la DPA 1998 (vigente antes de la entrada del estricto GDPR en 2018), las multas administrativas se reservaban para casos con intención delictiva probada o negligencia temeraria grave que provocara perjuicios o daños directos comprobables a los

individuos. La ICO consideró que el Trust y DeepMind actuaron de buena fe con el fin de desarrollar un software de innovación médica con el potencial de salvar vidas clínicas mediante la detección rápida de la insuficiencia renal.

En su lugar, la ICO requirió la firma de un **Compromiso Formal de Cumplimiento** (*Undertaking*), bajo el cual el *Royal Free London NHS Foundation Trust* se obligó legalmente a establecer una base legal sólida y explícita para todos sus proyectos tecnológicos presentes y futuros, rediseñar la documentación contractual con DeepMind (delimitando estrictamente los propósitos de procesamiento de datos en calidad de procesador de datos bajo control directo del hospital), completar una Evaluación de Impacto en la Privacidad (PIA/DPIA) del sistema de forma retrospectiva y ejecutar una auditoría técnica completa del tratamiento de datos en el ensayo clínico de Streams por un tercero independiente, cuyos resultados debían ser presentados directamente a la ICO.

Consecuencias posteriores y legado de Streams

El caso Royal Free/DeepMind impulsó cambios normativos en el sistema de salud del Reino Unido e internacionalmente:

- **Intervención de la National Data Guardian:** Fiona Caldicott, como asesora nacional de protección de datos de salud en Inglaterra, emitió dictámenes restrictivos respecto al "consentimiento implícito", delimitando que las actividades de validación, entrenamiento algorítmico, desarrollo técnico o investigación de software clínico no constituyen cuidado directo del paciente y requieren de forma obligatoria bases legales específicas o anonimización estricta.
- **Gobernanza de Streams:** La aplicación *Streams* continuó operando bajo un nuevo acuerdo legalmente sólido que incorporó de forma estricta las correcciones contractuales exigidas por la ICO y la auditoría técnica independiente. Posteriormente, tras la adquisición e integración de los activos de DeepMind Health por parte de Google Health, la infraestructura y el control de Streams pasaron a marcos organizativos con mayores niveles de escrutinio clínico y rendición de cuentas pública.

Ficha técnica de cumplimiento (Royal Free / DeepMind)

- **(a) Fuente primaria exacta:** *Information Commissioner's Office (ICO) Undertaking issued to Royal Free London NHS Foundation Trust* (3 de julio de 2017). Enlaces oficiales de la ICO: [Royal Free Undertaking PDF](#) y [Cover Letter](#).
- **(b) Cifras, fechas y definiciones precisas:**
 - **Cronología:** El Trust y Google DeepMind firman el acuerdo de compartición de datos el 30 de septiembre de 2015. La transferencia masiva en tiempo real (*data streaming*) de registros clínicos se inicia el 18 de noviembre de 2015. La ICO abre de oficio la investigación en mayo de 2016 tras una solicitud de FOI y revelación periodística de abril de 2016. La aplicación móvil *Streams* (dispositivo de Clase I registrado ante MHRA) entra en uso activo en vivo por clínicos del hospital en febrero de 2017. El dictamen de infracción e imposición del compromiso de cumplimiento obligatorio (*undertaking*) es emitido por la ICO el 3 de julio de 2017.
 - **Infracciones:** Transferencia masiva ilegítima de los expedientes de salud de aproximadamente 1.6 millones de pacientes históricos. Incumplió los Principios 1 (procesamiento justo/legal), 3 (datos excesivos para el propósito secundario de testeo), 6 (derechos del titular) y 7 (falta de evaluación de privacidad DPIA) de la DPA 1998.
 - **Ausencia de Multa:** Bajo el marco de la DPA 1998 (pre-GDPR), la imposición de multas económicas exigía demostrar dolo flagrante o daño directo cuantificable a

- los pacientes; el Trust actuó de buena fe intentando desarrollar una herramienta diagnóstica de beneficio clínico.
- **Consecuencias posteriores:** Firma del compromiso legal de cumplimiento (*undertaking*). Obligación de auditoría independiente retrospectiva. Llamado de atención de la National Data Guardian (Fiona Caldicott) delimitando que el "consentimiento implícito de salud" no cubre actividades de pruebas de seguridad ni desarrollo de software clínico.
 - **(c) Cita textual breve verídica:** El análisis legal de la ICO sobre el consentimiento implícito en este caso dictamina: "The processing of patient records by DeepMind significantly differs from what data subjects might reasonably have expected to happen to their data when presenting at the Royal Free for treatment."
 - **(d) Relevancia para el ingeniero biomédico:** Al planificar fases piloto, pruebas de concepto o validaciones de seguridad técnica para un software de IA en un hospital, el ingeniero no puede utilizar datos médicos crudos reales bajo la cobertura de "implícito cuidado directo". Debe implementar de forma obligatoria técnicas rigurosas de simulación sintética de datos clínicos o asegurar que se obtengan consentimientos informados explícitos de los pacientes específicos para testeo informático de software.

5. Tabla comparativa de cumplimiento normativo internacional

El análisis de las tres jurisdicciones clave revela cómo los objetivos de seguridad del paciente, la eficacia de los dispositivos y la privacidad de la información se abordan mediante metodologías contractuales, de auto-certificación o de escrutinio de terceros.

Eje Temático / Jurisdicción	Estados Unidos (FDA / HIPAA)	Argentina (ANMAT / AAIP)	Unión Europea (MDR / GDPR / AI Act)
Gobernanza del Dato (Eje 1)	Norma: HIPAA (45 CFR §164.514). Dato de Salud: Clasificado como ePHI bajo Covered Entities y Business Associates. Exige BAA firmado. Desidentificación: Safe Harbor (18 identificadores) o Expert Determination (análisis estadístico de riesgo). Sanciones: Multas severas (ej., Anthem USD 16M; brecha de Change Healthcare con costos de USD 2.457B).	Norma: Ley 25.326 y proyecto de reforma (Mensaje PEN 87/2023). Dato de Salud: Clasificado como "Dato Sensible" (Art. 2). Requiere consentimiento explícito para cesión o uso en I+D. Desidentificación: Disociación de datos (hacer inviable la asociación al titular). Sanciones: Sanciones administrativas de la AAIP. La reforma propone multas de hasta el 3% de la facturación local anual.	Norma: GDPR (Reglamento UE 2016/679). Dato de Salud: Categorías especiales de datos (Art. 9). Prohibición general de tratamiento, levantada por consentimiento explícito o salud pública. Desidentificación: Anonimización irreversible. La seudonimización sigue bajo el marco de GDPR. Sanciones: Multas de hasta 20M EUR o 4% de la facturación global anual del grupo.
Seguridad del Dispositivo (Eje 2)	Norma: FDA FD&C Act (sección 515C). Marco	Norma: Disposición ANMAT N° 9688/2019.	Norma: MDR (UE 2017/745) y

Eje Temático / Jurisdicción	Estados Unidos (FDA / HIPAA)	Argentina (ANMAT / AAIP)	Unión Europea (MDR / GDPR / AI Act)
	SaMD: Adopta criterios IMDRF de 4 categorías según gravedad médica e impacto informativo. Caminos: 510(k) (equivalencia sustancial), De Novo (bajo/moderado sin predicado), PMA (clínico riguroso). Cambios en IA: Plan de Control de Cambios Predeterminado (PCCP - dic 2024) permite actualizaciones automáticas preaprobadas.	Marco SaMD: El Art. 26 regula el software autónomo médico como "producto médico activo", inscribible en el RPPTM. Caminos: Registro sanitario obligatorio por clases de riesgo (I a IV). Exige justificar el cumplimiento de Requisitos Esenciales (RESE). Cambios en IA: No existe marco de PCCP formalizado aún; cambios de algoritmos críticos requieren modificaciones de registro de alta complejidad.	Reglamento de IA (EU AI Act). Marco SaMD: MDSW clasificado bajo MDR (Regla 11, clase IIa a III). Los dispositivos médicos con IA con marcado CE que requieren Notified Body son catalogados como "alto riesgo" (Art. 6(1)). Caminos: Evaluación de conformidad de Notified Bodies bajo el MDR. Cambios en IA: Alto nivel de escrutinio técnico del ciclo de vida e IA bajo directrices de Notified Body a partir de agosto de 2027.
Soporte de Hardware (Eje 3)	Normas: IEC 62304 (Ciclo de vida de software, clases A, B, C) e IEC 60601-1 (Seguridad eléctrica, Sec. 14 para PEMS). Cloud: BAA firmado por AWS/Azure/GCP bajo servicios del catálogo "HIPAA-Eligible". Encriptación: Obligatoria en reposo (AES-256) y en tránsito (TLS 1.2 o superior, se promueve TLS 1.3) y MFA universal bajo la regla de 2026.	Normas: IEC 62304 e IEC 60601-1 adoptadas como reglamentos técnicos de validación bajo requisitos RESE de ANMAT. Cloud: Permite el uso de nubes internacionales si el proveedor de la nube proporciona niveles adecuados o se firman contratos estándar de transferencia. Encriptación: Exigencia general de implementar medidas de seguridad física e informática proporcionales al riesgo de pérdida o sustracción de datos.	Normas: IEC 62304 e IEC 60601-1 armonizadas de forma obligatoria para la presunción de conformidad de marcado CE de software y PEMS. Cloud: Estricto cumplimiento de soberanía de datos del paciente y restricciones de flujos de datos transfronterizos bajo GDPR. Encriptación: El AI Act (Art. 15) exige niveles declarados de ciberseguridad, resiliencia a manipulación de datos y protección criptográfica del pipeline de IA.

Fuentes citadas

1. HIPAA Compliance - Amazon Web Services (AWS), <https://aws.amazon.com/compliance/hipaa-compliance/> 2. THIS AWS BUSINESS ASSOCIATE

ADDENDUM (this "Addendum") is an agreement between Amazon Web, <https://arlingtonvafoia.s3.dualstack.us-east-1.amazonaws.com/2019/3/002432.pdf> 3. HIPAA | Databricks on AWS, <https://docs.databricks.com/aws/en/security/privacy/hipaa> 4. PROCEDURE: HIPAA: Marketing and PHI Authority: 45 CFR 164.514(e)(1) - Hospice of North Idaho, https://hospiceofnorthidaho.org/wp-content/uploads/2015/02/PACKAGE_HIPPA-Privacy-Policy_assembled-3-29-2018.pdf 5. Guidance on Patient Privacy and the Publication or Dissemination of Case Reports, <https://www.hipaa.cuimc.columbia.edu/file/1111/download?token=sgaj36D3> 6. PHI Definition and 18 HIPAA Identifiers - Tadabase, <https://tadabase.io/blog/phi-definition-examples-identifiers> 7. Guidance Regarding Methods for De-identification of Protected Health Information in Accordance with the Health Insurance Portability and Accountability Act (HIPAA) Privacy Rule | HHS.gov, <https://www.hhs.gov/hipaa/for-professionals/special-topics/de-identification/index.html> 8. Guidance on Case Reports and Patient Privacy - Yale's HIPAA, <https://hipaa.yale.edu/sites/default/files/files/Case%20Reports%20and%20Patient%20Privacy.pdf> 9. HIPAA Expert Determination De-Identification Method - Network for Public Health Law, https://www.networkforphl.org/wp-content/uploads/2020/01/De_Identification_HIPAAExpertDetermination_CT.pdf 10. Guidelines and Methods for De-Identifying Protected Health Information - Institute for Families in Society - University of South Carolina, https://ifs.sc.edu/resources/documents/USC_IFS_PHIDDataDeIdentification_18_REV22.pdf 11. The Change Healthcare cybersecurity breach: Impact on healthcare providers, <https://www.nixonpeabody.com/insights/alerts/2025/11/12/change-healthcare-cybersecurity-breach-impact-on-healthcare-providers> 12. Change Healthcare Cyberattack Underscores Urgent Need to Strengthen Cyber Preparedness for Individual Health Care Organizations and as a Field, <https://www.aha.org/system/files/media/file/2025/02/Change-Healthcare-Cyberattack-Underscores-Urgent-Need-to-Strengthen-Cyber-Preparedness.pdf> 13. OCR reports 242 million records exposed in 2024 - Paubox, <https://www.paubox.com/blog/ocr-reports-242-million-records-exposed-in-2024> 14. Understanding the Change Healthcare Breach and Its Impact on Security Compliance, <https://hyperproof.io/resource/understanding-the-change-healthcare-breach/> 15. The HIPAA Security Rule 2026: What Hospital CISOs Must Do in 240 Days - Elisity, <https://www.elisity.com/blog/hipaa-security-rule-2026-240-days> 16. HIPAA Violation Statistics: 2026 Enforcement, Fines & Breach Data - FaxSIPit, <https://www.faxsipit.com/blogs/hipaa-violation-statistics> 17. Healthcare Data Breach Statistics – Updated for 2026 - The HIPAA Journal, <https://www.hipaajournal.com/healthcare-data-breach-statistics/> 18. Which Cloud for HIPAA? AWS vs Azure vs GCP (2026) - Of Ash and Fire, <https://www.ofashandfire.com/blog/hipaa-compliant-cloud-architecture-aws-azure-gcp> 19. HIPAA Compliance in Cloud Shared Responsibility - Censinet, <https://censinet.com/perspectives/hipaa-compliance-cloud-shared-responsibility> 20. Largest Healthcare Data Breaches of 2025 - The HIPAA Journal, <https://www.hipaajournal.com/largest-healthcare-data-breaches-of-2025/> 21. HIPAA Business Associate Agreement - 2026 Update, <https://www.hipaajournal.com/hipaa-business-associate-agreement/> 22. HIPAA-Eligible Cloud Platforms: AWS, Azure & Google Cloud (2026) | Medcurity, <https://medcurity.com/hipaa-cloud-compliance/> 23. Marco regulatorio de la Ley de Protección de Datos Personales en Argentina - Ministerio de Salud de Tierra del Fuego, <https://salud.tierradelfuego.gob.ar/wp-content/uploads/2025/01/Marco.pdf> 24. Proyecto 1751-D-2026 · Reforma de la Ley de Datos Personales, <https://www.leydedatospersonales.tech/> 25. Dirección Nacional de Protección de Datos

Personales - Jus.gob.ar,
<https://servicios.infoleg.gob.ar/infolegInternet/anexos/110000-114999/114376/norma.htm> 26. 1
 PROTECCION DE LOS DATOS PERSONALES Ley 25.326 Disposiciones Generales.
 Principios generales relativos a la protección de dato,
https://www.oas.org/juridico/pdfs/arg_ley25326.pdf 27. PROTECCION DE LOS DATOS -
 Jus.gob.ar - Infoleg,
<https://servicios.infoleg.gob.ar/infolegInternet/anexos/60000-64999/64790/texact.htm> 28.
 TEXTO ORIGINAL - RESOLUCIÓN 94 / 2023 - AGENCIA DE ACCESO A LA INFORMACION
 PUBLICA,
<https://www.argentina.gob.ar/normativa/nacional/resoluci%C3%B3n-94-2023-384189/texto> 29.
 AGENCIA DE ACCESO A LA INFORMACIÓN PÚBLICA - Resolución 161/2023 - BOLETIN
 OFICIAL REPUBLICA ARGENTINA,
<https://www.boletinoficial.gob.ar/detalleAviso/primera/293363/20230904> 30. Transparencia
 algorítmica - Portal Nacional de Transparencia - AAIP,
<https://portal.transparencia.gob.ar/transparencia/transparenciaAlgoritmica> 31. Argentina: La
 AAIP publicó la "Guía para entidades públicas y privadas en materia de transparencia y
 protección de datos personales para una inteligencia artificial responsable" - Baker McKenzie,
https://insightplus.bakermckenzie.com/bm/attachment_dw.action?attkey=FRbANEucS95NMLRN47z%2BeeOgEFct8EGQJsWJiCH2WAVkxTyloWy7GeqQTzaMisXP&nav=FRbANEucS95NMLRN47z%2BeeOgEFct8EGQbuwypnpZjc4%3D&attdocparam=pB7HEsg%2FZ312Bk8OluOIH1c%2BY4beLEAe6mUSnrEyjLw%3D&fromContentView=1 32. Guía para entidades públicas y
 privadas en materia de Transparencia y Protección de Datos Personales para una Inteligencia
 Artificial responsable - OCEDIC,
<https://ocedic.com/wp-content/uploads/2024/10/Guia-de-Transparencia-y-Proteccion-de-Datos-Personales.pdf> 33. La Autoridad de Protección de Datos Personales de Argentina publica su
 Guía para el Uso Responsable de la Inteligencia Artificial | IAPP,
<https://iapp.org/news/a/la-autoridad-de-proteccion-de-datos-personales-de-argentina-publica-su-guia-a-para-el-uso-responsable-de-la-inteligencia-artificial> 34. INTELIGENCIA ARTIFICIAL -
 Biblioteca del Congreso,
<https://bcn.gob.ar/biblioteca-digital/dossier-legislativo-inteligencia-artificial---abril-2026> 35.
 Processing of Health Data: GDPR, UK GDPR and Related Legal Frameworks,
<https://www.cpduk.co.uk/news/processing-health-data-gdpr-uk-gdpr-and-related-legal-frameworks> 36. EU AI Act for Medical Devices: SaMD Compliance Deadlines & Requirements - MDx
 CRO, <https://mdxcro.com/eu-ai-act-medical-devices-samd/> 37. Consolidated TEXT:
 32016R0679 — EN — 04.05.2016 - EUR-Lex - European Union,
<https://eur-lex.europa.eu/legal-content/EN/TXT/HTML/?uri=CELEX:02016R0679-20160504> 38.
 Art. 9 GDPR – Processing of special categories of personal data, <https://gdpr-info.eu/art-9-gdpr/>
 39. What are the conditions for processing? | ICO,
<https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/lawful-basis/special-categories-data/what-are-the-conditions-for-processing/> 40. Focus on Google DeepMind under the
 GDPR's Lens - Hogan Lovells,
<https://www.hoganlovells.com/en/publications/focus-on-google-deepmind-under-the-gdprs-lens>
 41. DATA PROTECTION ACT 1998 UNDERTAKING Data Controller: Royal Free London NHS
 Foundation Trust Pond Street Hampstead London NW32QG - medConfidential,
<https://medconfidential.org/wp-content/uploads/2018/05/royal-free-undertaking-03072017.pdf>
 42. Article 9(1) to (3) – Processing of special categories of data – Data concerning health -
 EUR-Lex, <https://eur-lex.europa.eu/legal-content/EN/TXT/HTML/?uri=CELEX:62021CJ0667> 43.
 EU AI Act High-Risk Compliance: Pharma & Medical Devices | IntuitionLabs,
<https://intuitionlabs.ai/articles/eu-ai-act-pharma-medical-device-compliance> 44. Artificial
 Intelligence in Software as a Medical Device - FDA,
<https://www.fda.gov/medical-devices/software-medical-device-samd/artificial-intelligence-software>

e-medical-device 45. Disposición ANMAT 9688/2019 | PDF | Software | Business - Scribd, <https://es.scribd.com/document/495336517/Disposicion-9688-2019> 46. SaMD Risk Categories (IMDRF): What They Mean & How They Relate to FDA Review, <https://www.complizen.ai/post/samd-risk-categories> 47. Global Approach to Software as a Medical Device - FDA, <https://www.fda.gov/medical-devices/software-medical-device-samd/global-approach-software-medical-device> 48. Software as a medical device (SaMD) - classification overview - Rimsys, <https://www.rimsys.io/blogs/software-as-a-medical-device-samd> 49. Healthcare Policy and AI Governance - The Physician AI Handbook, <https://physicianaihandbook.com/future/policy.html> 50. How the FDA's Predetermined Change Control Plan (PCCP) Framework Supports AI-Enabled Medical Devices - Intertek, <https://www.intertek.com/blog/2025/03-25-fdas-pccp-framework-and-ai-enabled-medical-devices/> 51. FDA Issues Final Guidance on PCCPs for AI-Enabled Devices - McDermott+, <https://www.mcdermottplus.com/insights/fda-issues-final-guidance-on-predetermined-change-control-plans-for-ai-enabled-devices/> 52. FDA Publishes Final Predetermined Change Control Plan Guidance for AI-Enabled Device Software Functions - King & Spalding, <https://www.kslaw.com/news-and-insights/fda-publishes-final-predetermined-change-control-plan-guidance-for-ai-enabled-device-software-functions> 53. CDRH Issues Guiding Principles for Predetermined Change Control Plans for Machine Learning-Enabled Medical Devices | FDA, <https://www.fda.gov/medical-devices/medical-devices-news-and-events/cdrh-issues-guiding-principles-predetermined-change-control-plans-machine-learning-enabled-medical> 54. FDA PCCP Explained: Managing Medical Device Changes - IntuitionLabs, <https://intuitionlabs.ai/articles/fda-predetermined-change-control-plan-pccp-guide> 55. Understanding FDA's Draft Guidance for Predetermined Change Control Plans (PCCPs) for Medical Devices Medical Device PCCP - Medcrypt, <https://www.medcrypt.com/blog/understanding-fdas-draft-guidance-for-predetermined-change-control-plans-pccps-for-medical-devices> 56. FDA Issues Comprehensive Draft Guidance for Developers of Artificial Intelligence-Enabled Medical Devices, <https://www.fda.gov/news-events/press-announcements/fda-issues-comprehensive-draft-guidance-developers-artificial-intelligence-enabled-medical-devices> 57. Pivotal trial of an autonomous AI-based diagnostic system for detection of diabetic retinopathy in primary care offices - PMC, <https://pmc.ncbi.nlm.nih.gov/articles/PMC6550188/> 58. NCT02963441 | A Multi-center Study to Evaluate Performance of an Automated Device for the Detection of Diabetic Retinopathy, <https://clinicaltrials.gov/study/NCT02963441> 59. Artificial Intelligence and Machine Learning in the Diagnosis and Management of Stroke: A Narrative Review of United States Food and Drug Administration-Approved Technologies - PMC, <https://pmc.ncbi.nlm.nih.gov/articles/PMC10253618/> 60. Real World Experience With Viz.AI Automated Large Vessel Occlusion Detection, <https://www.viz.ai/publications/experience-with-automated-lvo-detection> 61. AI Beyond the Clinic - CRSToday, <https://crstoday.com/articles/jan-2026/ai-beyond-the-clinic> 62. AI-powered stroke triage system performance in the wild - Open Access Journals, <https://www.openaccessjournals.com/articles/aipowered-stroke-triage-system-performance-in-the-wild.pdf> 63. Abstract 130: Real World Experience With Viz.AI Automated Large Vessel Occlusion Detection | Stroke - American Heart Association Journals, https://www.ahajournals.org/doi/abs/10.1161/str.53.suppl_1.130 64. Systematic analysis of the test design and performance of AI/ML-based medical devices approved for triage/detection/diagnosis in the USA and Japan - PMC, <https://pmc.ncbi.nlm.nih.gov/articles/PMC9542463/> 65. La norma DISPOSICIÓN 9688 / 2019 modifica las siguientes | Argentina.gov.ar, <https://www.argentina.gov.ar/normativa/nacional/disposici%C3%B3n-9688-2019-332646/normas-modificadas> 66. ADMINISTRACIÓN NACIONAL DE MEDICAMENTOS, ALIMENTOS Y

TECNOLOGÍA MÉDICA - Disposición 9688/2019 - BOLETIN OFICIAL REPUBLICA ARGENTINA, <https://www.boletinoficial.gob.ar/detalleAviso/primera/222600/20191203> 67. Disposición 9688 / 2019 - ADMINISTRACION NACIONAL DE MEDICAMENTOS, ALIMENTOS Y TECNOLOGIA MEDICA | Argentina.gob.ar, <https://www.argentina.gob.ar/normativa/nacional/disposici%C3%B3n-9688-2019-332646> 68. Disposición 9688/2019 - Cámara de Importadores de la República Argentina, <https://www.cira.org.ar/en/servicios/normativas-servicios/disposicion/disposicion-9688-2019/> 69. Gestión del Diseño y Desarrollo de Productos Médicos, <https://distancia.ingenieria.uner.edu.ar/mod/resource/view.php?id=23505> 70. Ministerio de Salud Secretaria de Calidad en Salud A.N.M.A.T. DECLARACION JURADA DE REVÁLIDA DISPOSICIÓN ANMAT N° 9688/2019 N, https://helena.anmat.gob.ar/uploads/pdfs/dj_25600_30523200751_2794.pdf?rnd=5a7e5699-5606-4b25-abbf-31d7039de33d 71. An Introduction to Software as a Medical Device (SaMD) - IntuitionLabs, <https://intuitionlabs.ai/articles/samd-definition-and-scope> 72. Understanding the IEC 60601-1 Medical Device Standard - Nectar Product Development, <https://nectarpd.com/iec-60601-1/> 73. TEXTO ACTUALIZADO - Disposición 9688 / 2019 - ADMINISTRACION NACIONAL DE MEDICAMENTOS, ALIMENTOS Y TECNOLOGIA MEDICA | Argentina.gob.ar, <https://www.argentina.gob.ar/normativa/nacional/disposici%C3%B3n-9688-2019-332646/actualizacion> 74. Understanding Risk Classification for SaMD - Hardian Health, <https://www.hardianhealth.com/regulatory/pre-market-risk-classification> 75. Article 6: Classification Rules for High-Risk AI Systems | EU Artificial Intelligence Act, <https://artificialintelligenceact.eu/article/6/> 76. AIB 2025-1 MDCG 2025-6 Interplay between the Medical Devices Regulation (MDR) & In vitro Diagnostic Medical Devices Regu - Public Health, https://health.ec.europa.eu/document/download/b78a17d7-e3cd-4943-851d-e02a2f22bbb4_en 77. TEXTO ORIGINAL - DISPOSICIÓN 9688 / 2019 - ADMINISTRACION NACIONAL DE MEDICAMENTOS, ALIMENTOS Y TECNOLOGIA MEDICA | Argentina.gob.ar, <https://www.argentina.gob.ar/normativa/nacional/disposici%C3%B3n-9688-2019-332646/texto> 78. Legislación Nacional - SAFYBI, <https://safybi.org/legislacion-nacional/> 79. What are the IEC 62304 Safety Classifications? - Greenlight Guru, <https://www.greenlight.guru/glossary/iec-62304> 80. Standard IEC 62304 - Medical device software - IET Digital Library, <https://digital-library.theiet.org/doi/pdf/10.1049/ic%3A20060141?download=true> 81. IEC 62304: Software development, the medical device version - FormlyAI, <https://blog.formly.ai/blog-post/iec-62304-software-development-the-medical-device-version/> 82. What is IEC 62304? Ensuring safety in medical software. - Revolve Healthcare, <https://revolve.healthcare/blog/what-is-iec-62304> 83. What is the difference between IEC 62304 and 60601 - IEC Equipment, <https://www.iec-equipment.com/new/new-54-852.html> 84. IEC 62304 Classifications Explained - Enlil, Inc., <https://enlil.com/blog/iec-62304-classifications-explained/> 85. The illustrated guide to medical device software development and IEC 62304, <https://medicaldevicehq.com/articles/the-illustrated-guide-to-medical-device-software-development-and-iec-62304/> 86. Characterization Considerations for Medical Device Software and Software- Specific Risk, https://www.imdrf.org/sites/default/files/2025-01/IMDRF_SaMD%20WG_Software-Specific%20Risk_N81%20Final_0.pdf 87. How to Build a HIPAA-Compliant Serverless Architecture (AWS, Azure, GCP) - Accountable, <https://www.accountablehq.com/post/how-to-build-a-hipaa-compliant-serverless-architecture-aws-azure-gcp> 88. 2025 Healthcare Data Breach Report - The HIPAA Journal, <https://www.hipaajournal.com/2025-healthcare-data-breach-report/> 89. Ministerio de Justicia y Derechos Humanos - Argentina - InfoLEG, <https://servicios.infoleg.gob.ar/infolegInternet/anexos/70000-74999/70448/norma.htm> 90. ICO

Ruling on Royal Free and Google DeepMind Trial - Society for Computers & Law,
<https://www.scl.org/6953-ico-ruling-on-royal-free-and-google-deepmind-trial/> 91. Google
DeepMind trial failed to comply with data protection law - Herbert Smith Freehills,
<https://www.hsfkramer.com/notes/data/2017-07/google-deepmind-trial-failed-to-comply-with-data-protection-law> 92. A Corporate Perspective on Data Protection - Niederer Kraft Frey,
https://www.nkf.ch/app/uploads/2022/09/171115_A-Corporate-Perspective-on-Data-Protection.pdf 93. Patient data were shared with Google on an “inappropriate legal basis,” says NHS data
guardian - Ovid,
<https://www.ovid.com/journals/bmjdpdf/10.1136/bmj.j2439~patient-data-were-shared-with-google-on-an-inappropriate> 94. Royal Free and Google DeepMind trial did not comply with DPA -
Digital Health,
<https://www.digitalhealth.net/2017/07/royal-free-and-deepmind-did-not-comply-with-dpa-ico/> 95.
Prismall -v- Google - Courts and Tribunals Judiciary,
<https://www.judiciary.uk/wp-content/uploads/2023/05/Prismall-v-Google.pdf> 96. ICE response
template- FOI Anonymised - ICO,
<https://ico.org.uk/media2/migrated/4025229/ic-233684-q0x3.pdf>